COMPTIA SECURITY+ SY0-701 | DOMAIN 2 · THREATS, VULNERABILITIES, AND MITIGATIONS (22%)

Security+ 2.4 · Password Attacks

Mestre CyberSec · **Lesson 2.4 — Password Attacks** (7:15) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Password attack: password spraying (UMA senha comum MUITOS usuários — evita lockout); credential stuffing (senhas VAZADAS reusadas); brute force (todas as combinações — rápido mas detectável); dictionary (lista de palavras); rainbow table (hash pré-computados — MORTO pelo SALTING

💡 Key Exam Highlights & Critical Concepts

- Password spraying: 1 senha fraca contra muitos usuários (discreto)
- Brute force = tentar tudo; dictionary = lista de palavras
- Rainbow table = hash pré-computada — MORTA pelo SALTING
- Reusa de senha vazada em outros sites = credential stuffing

🎯 Exam Tips & Typical CompTIA Scenarios

- 'single weak password tried against many accounts' = password spraying
- 'pre-computed hash table' = rainbow table (defesa: salting)

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 2.4 — Password Attacks)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Password Spraying (N/A)

An attack that tries a single common weak password against many different user accounts, often staying under lockout thresholds.

⚠️ ***Exam Trap:*** *Gatilho: 'uma senha fraca contra muitas contas' = password spraying. Não confunda com brute force/dictionary, que focam uma única conta.*

• Credential Stuffing (N/A)

Using breached username/password pairs from one service to authenticate to other services, exploiting password reuse.

⚠️ ***Exam Trap:*** *Gatilho: 'senhas vazadas reutilizadas em outros sites' = credential stuffing; difere de spraying porque usa pares usuário/senha vazados.*

• Brute Force Attack (N/A)

Trying every possible character combination until the correct password is found; can be online or offline.

⚠️ ***Exam Trap:*** *Gatilho: 'todas as combinações possíveis'. É barulhento/detectável online e pode causar lockout.*

• Dictionary Attack (N/A)

Using a list of common words, leaked passwords, and variations to guess passwords rather than trying all possible combinations.

⚠️ ***Exam Trap:*** *Gatilho: 'lista de palavras' ou 'wordlist'. Não tenta todas as combinações como o brute force.*

• Rainbow Table (N/A)

A precomputed table of password hashes used to quickly reverse unsalted password hashes.

⚠️ ***Exam Trap:*** *Gatilho: 'tabela de hashes pré-computados' = rainbow table; defesa principal: salting.*

• Salting (N/A)

Adding a unique random value to each password before hashing, stored with the hash, so identical passwords produce different hashes.

⚠️ ***Exam Trap:*** *Gatilho: salting torna rainbow tables inúteis. Não impede brute force, mas aumenta o custo; senhas iguais geram hashes diferentes.*

• Password Hash (N/A)

A one-way cryptographic representation of a password used for verification; if stolen, it can be attacked offline.

⚠️ ***Exam Trap:*** *Gatilho: hash não é criptografia; ataques offline usam hashes roubados. Salting e key stretching são defesas.*

• Key Stretching (N/A)

Applying repeated salted hashing to slow password verification and make brute-force or dictionary attacks more expensive.

⚠️ ***Exam Trap:*** *Gatilho: bcrypt, PBKDF2, Argon2 = key stretching. Defesa contra brute force/dicionário, especialmente offline.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Replay Attack

🏠 **Real-World Analogy:** Imagine a keyless car remote. When the owner presses the unlock button, it transmits a radio signal. An eavesdropper records the exact radio packet with an antenna. Late that night, the thief approaches the parked car and presses 'play' on the recording. The car processes the valid captured frequency and pops the locks, unable to discern a live transmission from a recorded playback.

🔍 **Root Cause & Background:** Protocols that inspect credentials or payload hashes without enforcing message freshness or sequencing. The adversary does not need to decrypt traffic or uncover passwords; retransmitting valid intercepted bytes suffices to authenticate.

🛡️ **GRC Auditor Perspective:** Audit transactional payment gateways and legacy authentication protocols against replay flaws; mandate strict deduplication filters and non-repeatable cryptographic handshake tokens.

⚠️ **How CompTIA Tests This:** Trigger: 'attacker intercepts valid authentication tokens or network packets and retransmits them later to gain unauthorized access without decrypting the payload'. Answer: Replay Attack.

📌 Cryptographic Nonce (Number Used Once)

🏠 **Real-World Analogy:** Think of a queue ticket numbered 001, 002, 003. When you present ticket 001 at the counter, the teller validates it and feeds it into a shredder. If a scammer picks up the discarded stub and attempts to reuse it ten minutes later, the teller announces: 'This number was already redeemed!' A nonce is a randomized unique number valid for only one exchange.

🔍 **Root Cause & Background:** To neutralize replay captures, servers issue an ephemeral, pseudorandom string. The client signs or binds this value into its cryptographic response; the server tracks used nonces, instantly rejecting identical submissions.

🛡️ **GRC Auditor Perspective:** Review corporate API specifications and external webhook endpoints; ensure nonce values and message authentication digests are validated server-side on every state-changing request.

⚠️ **How CompTIA Tests This:** Trigger: 'random or pseudorandom number issued in an authentication protocol to ensure that old communications cannot be reused in replay attacks'. Answer: Nonce (Number Used Once).

📌 Timestamping & Time Skew Windows (Kerberos)

🏠 **Real-World Analogy:** It is like a movie ticket stamped with a precise time: 'Admit One: October 21 at 7:00 PM only.' If someone tries to present that ticket the next morning, the usher turns them away because the authorization window has closed. In Kerberos networks, endpoints out of sync by more than five minutes are locked out.

🔍 **Root Cause & Background:** Binding packet validity to synchronized clock timestamps limits the viable capture-and-retransmit window to a negligible threshold. Authentication requests exceeding the permissible time skew tolerance are automatically dropped.

🛡️ **GRC Auditor Perspective:** Audit corporate Network Time Protocol (NTP) infrastructure; enforce strict time synchronization across Active Directory domains (maximum 5-minute Kerberos time skew) to prevent replay vulnerabilities and authentication failures.

⚠️ **How CompTIA Tests This:** Trigger: 'authentication protocol relies on synchronized system time and rejects tickets exceeding a maximum allowable time skew (typically 5 minutes) to defeat replay attacks'. Answer: Kerberos / Timestamps.

📌 Unique Session IDs & Ephemeral Tokens

🏠 **Real-World Analogy:** It is like a security wristband issued at an event that tears apart if unfastened. Every drink purchase updates a tamper-evident holographic stamp on the band. Presenting a photographed copy of an earlier wristband is rejected by the bar staff.

🔍 **Root Cause & Background:** Web systems maintaining static or overly persistent session cookies expose users to session hijacking. Generating high-entropy cryptographic identifiers rotated immediately upon authentication nullifies captured session replays.

🛡️ **GRC Auditor Perspective:** Inspect web session management configurations: mandate strict `Secure`, `HttpOnly`, and `SameSite=Strict` cookie flags combined with aggressive session timeout policies for idle sessions.

⚠️ **How CompTIA Tests This:** Trigger: 'countermeasure that regenerates a new session identifier upon successful user login to thwart session replay and fixation'. Answer: Session ID Rotation / Ephemeral Session Tokens.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Intercepting valid authentication traffic and retransmitting it later to gain unauthorized access	**Replay Attack**
Random cryptographic value used exactly once to invalidate duplicate captured transmissions	**Nonce (Number Used Once)**
Kerberos security mechanism that drops packets exceeding time synchronization thresholds	**Timestamping & Time Skew (5-minute Kerberos window)**
Core network protocol that must remain synchronized across domains to enforce replay protection	**NTP (Network Time Protocol)**
Practice of issuing a new randomized session identifier immediately following user authentication	**Session ID Rotation**
Attack wherein an adversary steals an active session cookie to impersonate a logged-in user	**Session Hijacking**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A security analyst sees authentication logs where a single source IP attempted the password Summer2024! against 300 different user accounts. Each account received only one failed login, and no account was locked out. The attempts continued every 45 minutes with a different common password. Which password attack best matches this behavior?

A) Credential stuffing using credentials from a third-party breach

B) Password spraying to avoid account lockout thresholds

C) Offline brute-force attack against captured password hashes

D) Rainbow table lookup against unsalted password hashes

QUESTION 2 · EXAM SCENARIO

Employees at a company report unauthorized VPN logins from unfamiliar locations. Investigation shows the attacker used a list of email addresses and passwords taken from an unrelated social media breach. A few logins succeeded because employees had reused their personal passwords at work. Which attack occurred?

A) Dictionary attack

B) Password spraying

C) Credential stuffing

D) Brute-force attack

QUESTION 3 · EXAM SCENARIO

A penetration tester extracts password hashes from a legacy application that uses unsalted MD5. Instead of submitting login attempts, the tester uses a very large precomputed mapping of hash values to plaintext passwords to recover several passwords quickly. Which technique is being used?

A) Rainbow table attack

B) Password spraying

C) Key stretching

D) Credential stuffing

QUESTION 4 · EXAM SCENARIO

A developer is updating an application's password storage. The security team wants to ensure that two users who choose the same password do not produce the same stored hash, and that precomputed lookup tables cannot be reused against the database. Which change should the developer implement?

A) Enforce a 90-day password expiration policy

B) Require multifactor authentication for all users

C) Configure account lockout after three failed attempts

D) Add a unique random value to each password before hashing it

QUESTION 5 · EXAM SCENARIO

A company must store password hashes for a high-value internal application. The security architect wants the hashing process to remain slow and resource-intensive even on modern hardware, so that offline guessing of each password takes much longer. Which technique should be selected?

A) Key stretching with bcrypt or PBKDF2

B) Password spraying prevention

C) Credential stuffing detection

D) Rainbow table generation

QUESTION 6 · EXAM SCENARIO

An attacker captures a password hash database from a server and then uses a tool that systematically tries every possible combination of letters, numbers, and symbols until the correct plaintext is found for one administrator account. Which type of attack is this?

A) Dictionary attack

B) Credential stuffing

C) Brute-force attack

D) Password spraying

QUESTION 7 · EXAM SCENARIO

During a web application assessment, a tester uses a list containing common passwords, seasons, and variations of the company name to guess user passwords. The tester tries the list against a single known username until a match is found. Which attack is being performed?

A) Rainbow table attack

B) Dictionary attack

C) Brute-force attack

D) Password spraying

QUESTION 8 · EXAM SCENARIO

A financial services firm allows users to authenticate to an internal portal. Attackers repeatedly try one common password across many employee accounts, waiting between attempts so that each account stays below the lockout threshold. Which control most directly mitigates this specific attack without relying only on account lockout?

A) Multifactor authentication

B) Increasing password maximum length

C) Disabling password history

D) Storing passwords with reversible encryption

QUESTION 9 · EXAM SCENARIO

An organization discovers that several user accounts were compromised because employees used the same passwords on corporate systems and personal websites that were later breached. The attackers simply replayed the leaked username and password pairs. Which additional control would best prevent this from succeeding in the future?

A) Password complexity requirements

B) Shorter password expiration intervals

C) Multifactor authentication

D) Unique salts in the password hash database

QUESTION 10 · EXAM SCENARIO

A security auditor finds that a database stores SHA-256 password hashes without a salt. The auditor warns that attackers could recover many passwords at once if the database is stolen. Which password attack is most directly mitigated by adding a unique salt to each password before hashing?

A) Password spraying

B) Credential stuffing

C) Dictionary attack

D) Rainbow table attack

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option B — Password spraying to avoid account lockout thresholds

Correct: Password spraying tries a few common passwords across many accounts to stay under lockout thresholds. The scenario shows one attempt per account across 300 accounts with repeated common passwords, not breached credential pairs, per-account brute force, or offline hash lookup. Credential stuffing would use previously breached username/password pairs; brute force would make many attempts per account; rainbow tables are offline precomputed hash attacks.

Question 2: Option C — Credential stuffing

Correct: Credential stuffing uses username/password pairs stolen from other breaches and replays them against a target, relying on password reuse. The scenario explicitly involves an unrelated breach and successful logins due to reused passwords. Password spraying uses common passwords across many accounts; dictionary uses wordlists; brute force enumerates all possibilities.

Question 3: Option A — Rainbow table attack

Correct: A rainbow table is a precomputed mapping of password hashes to plaintext, effective against unsalted hashes. Salting or key stretching with unique salts defeats precomputed tables. Password spraying and credential stuffing are online credential attacks, not offline precomputed hash lookups.

Question 4: Option D — Add a unique random value to each password before hashing it

Correct: Salting adds unique random data to each password before hashing, so identical passwords produce different hashes and precomputed tables cannot be reused. Password expiration, MFA, and lockout are useful controls but do not change hash uniqueness or defeat rainbow table reuse against stolen hashes.

Question 5: Option A — Key stretching with bcrypt or PBKDF2

Correct: Key stretching, such as bcrypt, PBKDF2, or Argon2, intentionally slows hashing with iterations or work factors, making offline guessing expensive. Password spraying and credential stuffing are attack methods, not defenses. Rainbow table generation is an attack; salting alone prevents precomputation but key stretching adds computational cost.

Question 6: Option C — Brute-force attack

Correct: Brute force systematically tries all possible combinations, which can eventually find a short or weak password but is noisy and slow. Dictionary uses a focused wordlist; credential stuffing replays breached pairs; password spraying tries a few common passwords across many accounts to avoid lockout.

Question 7: Option B — Dictionary attack

Correct: A dictionary attack uses a curated list of likely passwords and variations, often faster than exhaustive brute force against human-chosen passwords. Rainbow tables require captured hashes; brute force tries all combinations; password spraying targets many accounts with a few passwords.

Question 8: Option A — Multifactor authentication

Correct: MFA most directly mitigates password spraying because even if the common password is guessed for an account, the attacker still needs a second factor. Password length and complexity can help but do not directly stop the attack pattern; password history and reversible encryption are poor controls. Account lockout alone can be bypassed by spraying below thresholds across many accounts.

Question 9: Option C — Multifactor authentication

Correct: MFA prevents credential stuffing from succeeding with only a leaked username and password, because the attacker cannot provide the second factor. Complexity and expiration may reduce weak passwords but do not stop valid breached credentials from being replayed; salting protects stored hashes, not online authentication with valid leaked credentials.

Question 10: Option D — Rainbow table attack

Correct: Rainbow tables rely on precomputed hash values. A unique salt per password changes the hash output, so precomputed tables become ineffective. Password spraying and credential stuffing are online attacks using guessed or leaked credentials; dictionary attacks can still attempt guesses, but salting specifically defeats precomputed lookup tables.